

SIMATS ENGINEERING

ASSESSMENT TOOL 1

COURSE CODE: CSA51 COURSE NAME: Cryptography and Network Security

COURSE OUTCOME COVERED

CO5: *Develop the network security strategies based on the study of viruses, worms, firewall architectures, and IDS/IPS functionalities.CO (BL5, BL6)*

Assessment Tool Weightage: 40%

QUESTIONS: 5 TOTAL MARKS: 50 Annexure A
CONSTRAINT-BASED PROBLEM SOLVING

Code of Conduct:

I p.paneendra (192321072) certify that this submission is my original work and that I have adhered to the guidelines specified for this assessment. I understand that any violation of academic integrity rules will result in disciplinary action.

Signature of the student: p.paneendra

Annexure A

CONSTRAINT-BASED PROBLEM SOLVING

1. A financial institution must secure all web transactions using TLS, but legacy systems only support older SSL versions. Design a solution to ensure secure communication.

Constraints:

- A. Backward compatibility must be maintained for 20% legacy clients
 - B. Sensitive data must not be transmitted using SSL
 - C. System downtime must be minimal during migration
 - D. Cost of implementation should be optimized
-
2. An e-commerce platform is considering implementing the SET protocol for payment security but currently uses TLS-based encryption. Analyze and propose a decision.

Constraints:

- A. Must support high transaction throughput (10,000 transactions/minute)
 - B. Compatibility with modern browsers is required
 - C. Implementation complexity should be minimized
 - D. Regulatory compliance (PCI-DSS) must be ensured
-
3. A corporate network is experiencing repeated malware infections that spread rapidly without user interaction. Propose a containment and prevention strategy.

Constraints:

- A. The network consists of 500+ interconnected systems
 - B. Downtime per system should not exceed 10 minutes
 - C. Detection must occur within 2 minutes of infection
 - D. Solution must differentiate between virus, worm, and Trojan behavior
-
4. An organization needs to deploy a firewall architecture to protect its internal network from external threats and insider attacks. Design the solution.

Constraints:

- A. Must support both packet filtering and application-level inspection
- B. Latency introduced should not exceed 5 ms per request
- C. Should handle at least 1 Gbps traffic

- D. Must allow secure remote access for employees
5. A large enterprise network generates excessive false positives in its IDS, leading to alert fatigue. Propose an optimized IDS/IPS solution.

Constraints:

- A. Detection accuracy must be at least 95%
- B. False positive rate should be reduced below 5%
- C. System must process real-time traffic of 2 Gbps
- D. Solution should integrate with existing firewall infrastructure

ANSWER

1. Secure Web Transactions with TLS and Legacy SSL Clients

The financial institution should migrate its web infrastructure to TLS 1.2 and TLS 1.3 while isolating the 20% of legacy clients that cannot support modern TLS. Since sensitive data must never be transmitted using SSL, legacy systems should not be allowed to access sensitive financial services directly.

A. Backward compatibility

A dual-access architecture can be used:

Modern Clients → TLS 1.3/TLS 1.2 → Secure Web Server

Legacy Clients → Compatibility Gateway → TLS 1.2/TLS 1.3 → Secure Web Server

The compatibility gateway acts as a controlled intermediary for legacy clients. SSL traffic should terminate only in an isolated legacy zone, and sensitive transactions should be blocked from those clients.

B. Protecting sensitive data

Sensitive information such as:

- Account credentials
- Credit/debit card information
- Banking transactions
- Personal information

must be transmitted only through TLS 1.2 or TLS 1.3.

SSL 2.0 and SSL 3.0 should be completely disabled for sensitive applications because they contain

known security weaknesses.

C. Migration with minimum downtime

Migration can be performed gradually:

Step 1: Identify all SSL-dependent clients.

Step 2: Upgrade clients that support TLS.

Step 3: Deploy a compatibility gateway for unavoidable legacy clients.

Step 4: Enable TLS 1.2/1.3 on production servers.

Step 5: Test applications using a small percentage of users.

Step 6: Gradually move all clients to TLS.

Step 7: Disable legacy SSL after the migration period.

This approach allows migration without taking the entire system offline.

D. Cost optimization

The organization can reduce costs by:

- Reusing existing load balancers or reverse proxies as TLS gateways.
- Upgrading software instead of replacing all hardware.
- Prioritizing high-risk systems first.
- Using automated certificate management.
- Phasing out legacy clients gradually.

Recommended solution: TLS 1.3 should be the preferred protocol, with TLS 1.2 maintained for compatibility. Legacy SSL clients should be isolated and prevented from handling sensitive transactions.

2. SET vs TLS for E-Commerce Payment Security

The Secure Electronic Transaction (SET) protocol was designed specifically to protect online card payments. However, modern e-commerce systems generally use TLS with secure payment gateways rather than SET.

A. Transaction throughput

The requirement is 10,000 transactions per minute, which is approximately 167 transactions per second.

TLS is well suited to high-throughput environments because modern TLS implementations

support:

- Efficient encryption.
- Session resumption.
- Hardware acceleration.
- Modern cryptographic algorithms.
- Scalable server architectures.

SET introduces additional cryptographic operations and certificate-management requirements, which can increase processing complexity.

B. Browser compatibility

Modern browsers and web platforms have built-in support for TLS.

SET is not commonly supported by modern browsers and would require additional software or specialized payment infrastructure.

Therefore, TLS provides much better compatibility.

C. Implementation complexity

SET requires several components, including:

- Digital certificates.
- Merchant certificates.
- Customer certificates.
- Payment gateways.
- Additional transaction-processing mechanisms.

TLS provides a simpler architecture:

Customer Browser → TLS → E-Commerce Server → Secure Payment Gateway → Bank

Therefore, TLS is significantly easier to deploy and maintain.

D. PCI-DSS compliance

TLS can be configured as part of a PCI-DSS-compliant payment architecture. The organization should use strong encryption, secure configurations, proper access control, logging, vulnerability management, and appropriate protection of cardholder data.

SET itself does not automatically guarantee PCI-DSS compliance. Compliance depends on the overall security architecture and operational controls.

Decision

The organization should continue using TLS rather than implementing SET.

TLS provides:

- Better browser compatibility.
- Higher scalability.
- Lower implementation complexity.
- Strong modern encryption.
- Easier integration with payment gateways.
- Better suitability for 10,000 transactions/minute.

For payment-card processing, sensitive card data can also be handled by a PCI-compliant payment gateway to reduce the organization's card-data exposure.

3. Malware Containment and Prevention Strategy

The organization has more than 500 interconnected systems, and malware is spreading without user interaction. This behavior strongly suggests rapidly propagating malware such as a worm, although virus and Trojan behavior must also be distinguished.

A. Network segmentation

The first step should be to divide the network into security zones.

For example:

Internet → Firewall → DMZ → Internal Network → Critical Systems

The internal network should further be divided into VLANs or security segments.

If one system becomes infected, the malware should not be able to freely communicate with all 500+ systems.

B. Detection within two minutes

An endpoint detection and response system can continuously monitor:

- New processes.
- File modifications.
- Network connections.
- Suspicious executable activity.
- Registry/system changes.
- Unusual authentication behavior.

Network IDS/IPS sensors should also monitor for:

- Port scanning.
- Rapid connection attempts.
- Abnormal traffic.

- Known malware signatures.
- Suspicious lateral movement.

When a system is identified as infected, automated response should immediately isolate it from the network.

C. Automated containment

The process can be:

Infection → Detection → Risk Analysis → Endpoint Isolation → Alert Security Team → Malware Removal → Verification → Reconnection

The isolation process should be automated so that detection and containment can occur within the required two-minute window.

D. Differentiating malware types

Virus:

A virus attaches itself to another file or program and spreads when the infected file is executed or shared.

Worm:

A worm is capable of self-propagation across networks without requiring the user to execute an infected file. Rapid network scanning and repeated connection attempts are strong indicators.

Trojan:

A Trojan usually disguises itself as legitimate software and depends on the user or another process to execute it. It may establish unauthorized access or steal information.

The detection system should use both endpoint behavior and network behavior to distinguish these patterns.

E. Prevention

The organization should implement:

- Endpoint protection.
- Automatic security updates.
- Network segmentation.
- Application allowlisting.
- Least-privilege access.
- Email and web filtering.
- Vulnerability scanning.
- IDS/IPS monitoring.
- Centralized security logging.
- Regular security awareness training.

To meet the 10-minute downtime requirement, automated endpoint isolation should be used

instead of manually disconnecting systems.

4. Firewall Architecture for External and Insider Threats

A multi-layer firewall architecture should be deployed to provide both network-level filtering and application-level inspection.

A. Proposed architecture

The architecture can be:

Internet → Perimeter Firewall → DMZ → Internal Firewall → Internal Network

The perimeter firewall protects against external attacks.

The DMZ contains publicly accessible systems such as:

- Web servers.
- Mail gateways.
- DNS servers.
- Public application servers.

The internal firewall separates the DMZ from sensitive internal systems.

B. Packet filtering

The firewall should inspect:

- Source IP.
- Destination IP.
- Source port.
- Destination port.
- Protocol.
- Connection state.

Only required traffic should be allowed.

For example:

Internet → Web Server: HTTPS allowed

Internet → Internal Database: Blocked

C. Application-level inspection

A next-generation firewall or application-aware firewall should inspect application traffic.

It can identify:

- HTTP/HTTPS applications.
- Malware.
- Suspicious commands.
- Unauthorized applications.
- Abnormal protocols.

This provides greater protection than simple packet filtering.

D. Protection against insider attacks

Internal segmentation should be used to limit communication between departments and critical systems.

For example:

Employee Network → Application Server → Database

Employees should not have direct access to the database unless required.

Additional controls should include:

- User authentication.
- Network access control.
- Logging.
- Monitoring.
- Least privilege.
- Internal IDS/IPS.

E. Remote employee access

Employees should use a secure VPN, preferably with:

- Strong authentication.
- Multi-factor authentication.
- Encryption.
- Device verification.
- Role-based access.

Remote users should not receive unrestricted access to the internal network.

F. Performance requirements

The firewall should be selected and configured to support at least 1 Gbps throughput while maintaining the required inspection features.

To keep latency below 5 ms per request, the organization should use appropriately sized hardware, hardware acceleration where available, efficient security policies, and avoid unnecessary deep

inspection of trusted low-risk traffic.

Recommended architecture:

Internet → High-performance NGFW → DMZ → Internal Segmentation Firewall → Internal Systems

This provides layered protection against both external and internal threats.

5. Optimized Enterprise IDS/IPS Solution

The enterprise is experiencing too many false positives, resulting in alert fatigue. The solution should combine signature-based detection, behavioral analysis, threat intelligence, and automated response.

A. Improved IDS/IPS architecture

The architecture can be:

Internet → Firewall → IDS/IPS → Internal Network

Additional IDS/IPS sensors can be placed inside important network segments.

The IDS/IPS should integrate with the existing firewall so that detected malicious traffic can automatically trigger firewall rules.

B. Reducing false positives

False positives can be reduced by combining multiple detection methods.

The system should consider:

- Attack signatures.
- Source reputation.
- Destination reputation.
- Traffic behavior.
- User behavior.
- Historical activity.
- Threat intelligence.
- Asset criticality.

Instead of treating every suspicious event equally, the system should calculate a risk score.

For example:

Low Risk → Log

Medium Risk → Alert/Security Review

High Risk → Block + Alert

C. Machine-learning and behavioral detection

Machine-learning models can establish normal network behavior and detect unusual activity.

For example, if a server normally communicates with five internal systems but suddenly starts making thousands of connections to external addresses, the system can identify this as suspicious.

Behavioral detection can identify previously unknown attacks that may not have existing signatures.

D. Achieving 95% detection accuracy

The system should use:

- Regularly updated signatures.
- Threat intelligence feeds.
- Behavioral analysis.
- Machine-learning models.
- Continuous rule tuning.
- Security analyst feedback.

Detection rules should be regularly reviewed so outdated or noisy rules can be modified or removed.

E. Processing 2 Gbps traffic

The IDS/IPS infrastructure should be sized to support at least 2 Gbps real-time traffic.

High-performance appliances or distributed sensors can be used.

Traffic can be distributed across multiple sensors using load balancing if required.

F. Integration with firewall

The IDS/IPS and firewall should share threat information.

For example:

IDS Detects Attack → Generates High-Severity Alert → Sends Indicator to Firewall → Firewall Blocks Source → SIEM Records Event

A centralized SIEM can collect and correlate events from:

- IDS/IPS.
- Firewalls.
- Servers.

- Endpoints.
- Authentication systems.

G. Expected result

The optimized solution should aim for:

- Detection accuracy: $\geq 95\%$
- False-positive rate: $< 5\%$
- Traffic processing: ≥ 2 Gbps
- Real-time monitoring: Enabled
- Firewall integration: Enabled
- Automated blocking: For high-confidence threats

This approach reduces alert fatigue while maintaining strong protection against both known and emerging attacks.

